

SPÉCIFICATIONS FONCTIONNELLES & TECHNIQUES

CGK CRM

commercial • devis • facturation

Document de référence destiné à l'équipe de développement. Réception et traitement des leads issus de campagnes d'acquisition, gestion du cycle commercial complet, signature électronique des devis, planification d'interventions, comptabilité (devis, factures d'acompte et finales) et gestion multi-entités juridiques.

Sommaire

Préambule et lecture du document	1
1. Vision produit et contexte fonctionnel	2
2. Workflow métier de bout en bout	5
3. Modèle de rôles, permissions et cloisonnement	8
4. Modules fonctionnels — écran par écran	11
5. Modèle de données	21
6. Architecture technique recommandée	25
7. Intégrations externes	28
8. Sécurité informatique — points de vigilance	31
9. Performance, accessibilité et UX	35
10. Roadmap de développement proposée	36
11. Critères d'acceptation	37
Annexes — glossaire, conventions, endpoints	38

Lecture du document

Ce cahier des charges décrit l'intégralité du périmètre fonctionnel et technique du **CGK CRM**, application commerciale interne destinée à une PME opérant dans la prestation de services à destination de prospects particuliers et professionnels (B2B et B2C). Le document s'appuie sur la version 2 de l'interface, conçue après un cycle d'itérations sur la maquette, et fixe les comportements attendus, les structures de données, les intégrations externes et les exigences de sécurité, dans une qualité de spécification permettant un démarrage sans ambiguïté de la phase d'ingénierie.

Le document est structuré en onze sections numérotées, suivies d'annexes. Les sections 1 à 4 cadrent la vision produit, les utilisateurs, le cycle de vie d'un lead, et les modules fonctionnels écran par écran tels qu'ils existent dans la maquette. Les sections 5 à 8 entrent dans la spécification technique (modèle de données, architecture, intégrations, sécurité). Les sections 9 à 11 formalisent les attentes non fonctionnelles, le phasage de livraison et les critères d'acceptation.

CONVENTIONS DE LECTURE

Les éléments en `typographie monospace` désignent des identifiants techniques (tables, champs, endpoints, slugs). Les encadrés colorés signalent un point d'attention (violet : note structurante, vert : recommandation validée ou règle métier, jaune : point de vigilance technique ou de sécurité).

Le document est anonymisé : les noms d'utilisateurs et de société du commanditaire sont remplacés par des désignations génériques (« le client », « le commanditaire », « Commercial #n », « Entité #n »). Les volumétries et exemples sont fournis à titre indicatif pour calibrer les ordres de grandeur, et la maquette de référence a été construite avec un jeu de données fictif mais réaliste.

Vision produit et contexte fonctionnel

1.1 Objectif du projet

Le **CGK CRM** centralise la gestion commerciale d'une équipe distribuée traitant des leads entrants à fort volume, issus de campagnes publicitaires payantes (Google Ads, Meta Ads), de formulaires sur landing pages, du site institutionnel, du téléphone direct et de la recommandation. L'enjeu principal est triple : industrialiser le suivi commercial du lead jusqu'à l'encaissement final, augmenter le taux de transformation grâce à une relance automatisée des prospects difficiles à joindre, et fournir un pilotage temps réel à la direction sur les indicateurs de performance commerciale et financière.

L'application remplace un outillage hétérogène (tableurs partagés, échanges email manuels) par une plateforme unique qui matérialise un cycle commercial standardisé en six étapes (Lead entrant → Devis envoyé → Devis ouvert → Signé → Encaissé, avec une voie « Perdu »), génère devis, factures d'acompte et factures finales aux normes d'une comptabilité multi-entités, déclenche la signature électronique sans friction et synchronise les conversions vers les régies publicitaires pour optimiser le retour sur investissement.

1.2 Périmètre couvert

Domaine	Fonctionnalités principales
Acquisition	Réception automatisée des leads, attribution par activité, traçabilité de la source (5 sources : Google Ads, Meta Ads, Recommandation, Site web, Téléphone direct).
Commercial	Pipeline Kanban 6 colonnes, fiche lead, génération de devis depuis catalogue de prestations, envoi par email avec lien de signature électronique, séquence de relance automatisée, sous-statuts canal Mano/Auto.
Comptabilité	Module dédié avec onglets Devis / Factures d'acompte / Factures finales, fichier Clients (issus de leads ou créés directement), éditeur de devis, vue document, génération PDF, suivi du statut d'encaissement.
Production	Planification des interventions, vue planning partagée par bloc temporel (Aujourd'hui / Cette semaine / À venir / Passées), encart « acomptes à encaisser », assignation de techniciens.
Pilotage	Dashboard temps réel avec filtres globaux (période × activité), KPIs commerciaux et financiers, classement de l'équipe, couverture géographique France par département.
Configuration	Six sous-onglets : utilisateurs & rôles, entités juridiques (multi-société), secteurs d'activité, modèles documentaires (matrix Entité × Activité × Type), sources de leads, intégrations.

1.3 Utilisateurs cibles et volumétries

L'application sert une équipe initiale de neuf à dix utilisateurs, répartie sur plusieurs villes françaises, appelée à croître. Les profils sont détaillés dans la section 3 (modèle de rôles). À titre indicatif : un dirigeant (Super Admin cumulant le rôle Commercial), cinq commerciaux opérationnels, deux planificateurs, un assistant administratif (rôle activé en phase 2).

~150 LEADS / MOIS	~80 DEVIS ÉMIS / MOIS	~30 DEVIS SIGNÉS / MOIS	10+ UTILISATEURS SIMULTANÉS
-----------------------------	---------------------------------	--------------------------------------	--

Ces ordres de grandeur servent de référence pour le dimensionnement initial. L'application doit néanmoins supporter une croissance d'au moins 5× sans refonte structurelle (~750 leads/mois et 50 utilisateurs simultanés). La couverture géographique cible est l'ensemble du territoire français métropolitain.

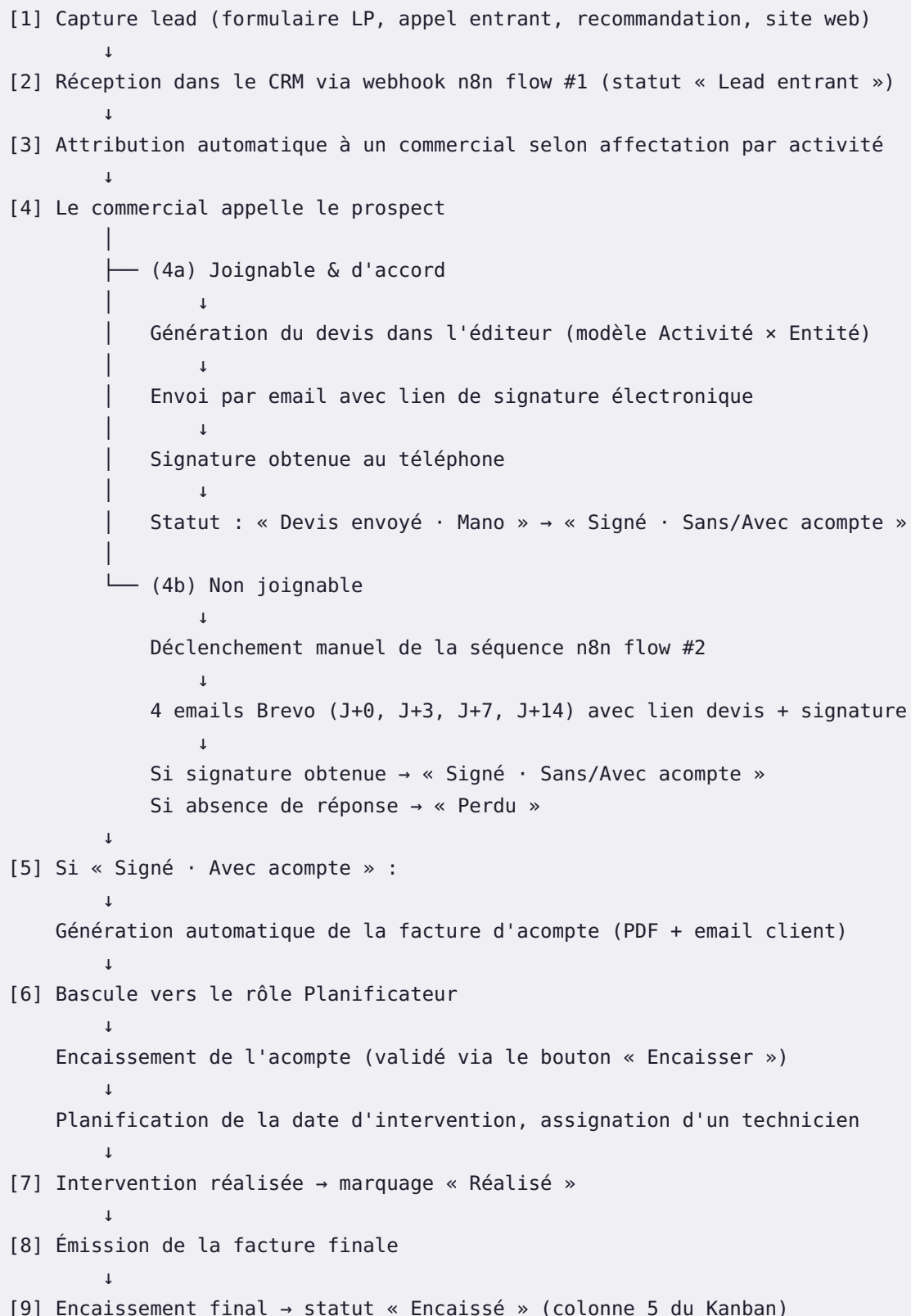
1.4 Glossaire métier

Terme	Définition
Lead	Prospect ayant manifesté un intérêt via un formulaire, un appel ou une recommandation. Synonyme : contact entrant.
Pipeline	Représentation visuelle Kanban (6 colonnes) du cycle commercial.
Sous-statut Mano / Auto	Canal d'envoi du devis : mano = envoi manuel par le commercial après accord téléphonique, auto = séquence email Brevo orchestrée par n8n. Le badge est REQUIS sur tout devis envoyé ; un badge rouge « Canal manquant » apparaît sinon.
Sous-statut Sans / Avec acompte	Distinction au moment de la signature : sans = paiement à la livraison, avec = un acompte est dû à la signature, ce qui déclenche la génération automatique de la facture d'acompte.
Activité / Secteur	Catégorie de prestation (4 secteurs initiaux). Pilote le routing des leads, les modèles documentaires applicables, le pourcentage d'acompte par défaut, et le taux de TVA appliqué.
Entité juridique	Société émettrice d'un devis ou d'une facture. Le CRM gère un nombre illimité d'entités (multi-société).
Annotation Immobilier / Travaux	Champ confidentiel attaché au lead, visible uniquement par les utilisateurs explicitement habilités via la permission immobTravaux .
Vue (rôle actif)	Sélecteur permettant à un utilisateur multi-rôles de basculer la perspective d'affichage. Inclut un mode « aperçu lecture seule » des autres rôles non possédés.

Workflow métier de bout en bout

2.1 Cycle de vie d'un lead — vue d'ensemble

Le parcours commercial standard d'un lead, depuis sa capture jusqu'à l'encaissement final, suit la séquence détaillée ci-dessous. La compréhension de ce cycle est cruciale pour implémenter correctement la machine à états et les transitions automatiques.



2.2 Workflow n8n flow #1 — Réception des leads

Le flow #1 capte les soumissions de formulaires sur les landing pages, normalise les données reçues, enrichit éventuellement le lead (recherche d'informations publiques sur l'entreprise prospect) et appelle l'endpoint `POST /api/webhooks/leads/inbound` du CRM. Le payload attendu est un JSON typé contenant : un identifiant d'idempotence (`external_id`), le timestamp de réception, la source, l'activité, les coordonnées du client, les paramètres de tracking (`gclid`, `utm_*`), un éventuel montant estimé. La signature HMAC du payload doit figurer dans le header `X-Signature` .

Le CRM doit être robuste aux livraisons partielles (champs manquants), aux doublons (déduplication par combinaison téléphone + email + créneau de réception) et aux attaques par rejeu (vérification HMAC + fenêtre temporelle sur le timestamp).

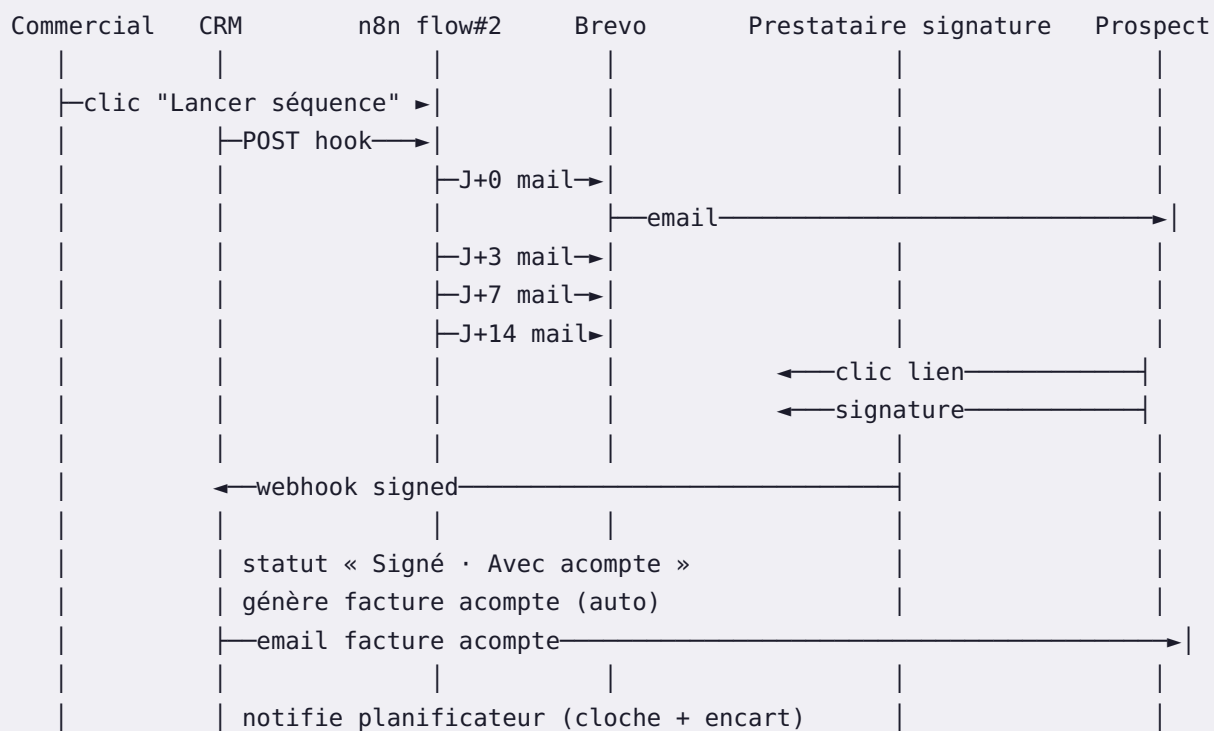
2.3 Workflow n8n flow #2 — Séquence de relance email

Le flow #2 est déclenché manuellement par un commercial depuis l'interface du CRM, exclusivement quand le prospect n'a pas pu être joint au téléphone (carte en colonne « Lead entrant » ou « Devis envoyé · Mano » non encore signé). Le commercial clique sur le bouton hover « **Lancer séquence** » de la carte Kanban, un modal de confirmation s'affiche avec le détail de la séquence prévue, et la confirmation appelle `POST /api/leads/{id}/trigger-sequence` . Le statut du lead bascule en « **Devis envoyé · Auto** », et n8n orchestre l'envoi des 4 emails programmés selon la cadence ci-dessous.

Délai	Email	Sujet pédagogique
J+0	Email 1	Devis envoyé — récapitulatif & lien signature
J+3	Email 2	Relance douce — répondre aux questions éventuelles
J+7	Email 3	Relance commerciale — bénéfices & témoignages
J+14	Email 4	Dernière relance — clôture / proposition d'appel

La séquence s'arrête automatiquement si le client signe ou répond. Quand la signature est obtenue via cette voie, le prestataire de signature électronique notifie le CRM (`POST /api/webhooks/signature/signed`), qui passe le devis en « **Signé · Sans/Avec acompte** » selon le paramétrage initial. Cette distinction Mano / Auto est essentielle pour mesurer la performance des deux canaux et arbitrer l'investissement publicitaire et opérationnel.

2.4 Diagramme de séquence — devis signé via la séquence Auto



Modèle de rôles, permissions et cloisonnement

3.1 Les quatre rôles

Le système de permissions repose sur quatre rôles fonctionnels. Un utilisateur peut cumuler plusieurs rôles (multi-rôles). Les permissions effectives sont l'union des permissions de chaque rôle assigné. L'utilisateur bascule sa **vue active** depuis le sélecteur du header. Un mode aperçu lecture seule est également proposé pour les rôles non possédés (utile pour le Super Admin qui souhaite vérifier ce que voit un autre rôle).

Super Admin

1 utilisateur initial

Accès illimité à toutes les pages, données et configurations. Seul rôle habilité à inviter / désactiver des utilisateurs, à attribuer rôles et activités, à gérer les entités juridiques, les modèles documentaires, les secteurs, les sources, les intégrations. Peut accorder ou retirer la permission `immobTravaux` (cf. 3.5).

Commercial

5 utilisateurs initiaux

Voit uniquement les leads dont il est propriétaire (cloisonnement strict `access.leads = 'mine'`). Indicateurs personnels (ses leads, ses devis, son CA signé, son taux de transformation). Affecté à une ou plusieurs activités pour la pré-attribution automatique des leads entrants. Accès en lecture / écriture à la fiche lead, génération de devis, déclenchement manuel de la séquence n8n flow #2.

Planificateur

2 utilisateurs initiaux

Vue planning partagée sans cloisonnement par activité. Accès au Dashboard en mode global (lecture), aux Leads en lecture seule pour le contexte, à la Planification en CRUD complet, à la Comptabilité en CRUD complet (encaissement acompte, émission facture finale, suivi encaissement). Pas d'accès au Pipeline commercial ni à l'écran Commerciaux ni aux Paramètres.

Assistant

À activer en phase 2

Rôle prévu en phase 2. Périmètre à formaliser : appui administratif sur la qualification, le suivi documentaire, les relances administratives. À l'initialisation : aucun écran accessible (matrice `access.* = false`). Un utilisateur portant uniquement ce rôle voit l'écran « Accès non disponible pour ce rôle » au login.

3.2 Multi-rôles et bascule de vue

Un même utilisateur peut être assigné à plusieurs rôles simultanément. C'est notamment le cas du dirigeant qui cumule Super Admin et Commercial pour traiter directement certains leads stratégiques. La fiche utilisateur propose une multi-sélection de rôles. Le sélecteur de rôle dans le header propose deux groupes : **Mes rôles** (les rôles réellement assignés à l'utilisateur, qui basculent réellement la vue) et **Aperçu (lecture seule)** (les autres rôles, accessibles à des fins de vérification, sans capacité d'écriture).

3.3 Matrice d'accès aux modules

Module	Super Admin	Commercial	Planificateur	Assistant
Dashboard	full	mine (KPIs perso)	full (lecture)	—
Pipeline	full	mine (ses cartes)	—	—
Leads & devis	full	mine (ses leads)	readonly	—
Commerciaux	true	—	—	—
Planification	true	—	true (CRUD)	—
Comptabilité	true	—	true (CRUD)	—
Paramètres	true	—	—	—

Modes : **full** = vue globale toutes données ; **mine** = uniquement les enregistrements dont l'utilisateur est propriétaire ; **readonly** = lecture sans modification ; **true** = accès simple ; **—** = aucun accès. Un module non accessible n'apparaît pas dans la sidebar du rôle concerné.

3.4 Cloisonnement appliqué côté base de données

RÈGLE TECHNIQUE

Le cloisonnement de données ne doit pas reposer sur le filtrage côté UI uniquement. Toute table métier doit porter une **politique RLS Supabase** (Row Level Security) qui filtre les lignes selon l'utilisateur authentifié et ses rôles. Un attaquant qui forge des requêtes directes (par ex. via la clé anon publique) ne doit jamais pouvoir exfiltrer les leads d'un autre commercial. Voir 8.2.

3.5 Permission granulaire — annotation Immobilier / Travaux

Le champ **annotation Immobilier / Travaux** est un champ confidentiel attaché à chaque lead, dont la visibilité est contrôlée par une permission nominative `immobTravaux` portée par le profil utilisateur (booléen). Un utilisateur sans cette permission ne voit ni le champ ni son contenu, même s'il est propriétaire du lead. La permission est attribuée et révoquée uniquement par le Super Admin depuis la fiche utilisateur, et s'applique en plus du cloisonnement de rôle (pas en remplacement).

3.6 Affectation des commerciaux par activité

Chaque commercial peut être affecté à une ou plusieurs activités parmi les secteurs configurés. Cette affectation pilote la pré-attribution automatique des leads entrants (un lead arrivant sur l'activité A est attribué prioritairement à un commercial dont l'affectation inclut A). Le Super Admin peut multi-allouer un commercial à plusieurs activités à la volée, sans plafond. L'affectation par activité est **indépendante** de la visibilité des leads : un commercial voit toujours uniquement ses propres leads (ceux qui lui sont attribués), pas l'ensemble des leads de ses activités.

3.7 Profil utilisateur — vue d'ensemble des champs

Champ	Type	Description
<code>id</code>	uuid	Identifiant unique
<code>name</code>	string	Nom complet affiché
<code>initials</code>	string(2)	Initiales pour l'avatar généré
<code>email</code>	string	Email professionnel, unique
<code>team</code>	string	Ville / équipe de rattachement (Paris, Lyon...)
<code>roles</code>	array	Liste des rôles : <code>['admin', 'commercial', 'planification', 'assistant']</code>
<code>sectors</code>	array	Activités affectées (commerciaux uniquement)
<code>permissions.immobTravaux</code>	bool	Permission granulaire annotation confidentielle
<code>color</code>	hex	Couleur d'avatar (utilisée dans toute l'UI)
<code>is_active</code>	bool	Compte actif ou désactivé

Modules fonctionnels — écran par écran

4.1 Sidebar & topbar (squelette d'application)

L'application présente un layout type SaaS classique en deux parties : une **sidebar** verticale gauche rétractable (240 px / 56 px en mode replié) et une **topbar** horizontale fine. La sidebar regroupe la navigation principale (section **Pilotage**) et la configuration (section **Configuration**) ; le footer sidebar contient les actions **Réduire** et **Mode sombre**.

La topbar contient : la barre de recherche globale (déclenche la **palette de commandes** via raccourci `⌘K` / `Ctrl+K`), les **filtres globaux** Période et Activité, les notifications (cloche avec pastille), le **sélecteur de Vue** (rôle actif) et le menu utilisateur.

Navigation Pilotage

Six entrées : `/dashboard`, `/pipeline`, `/leads` (avec compteur de leads non traités), `/commerciaux`, `/planification`, `/comptabilite`.

Navigation Configuration

Une seule entrée : `/settings`, avec un onglet latéral interne pour les six sections de paramétrage.

Palette de commandes (`⌘K`)

Composant overlay déclenché au raccourci clavier ou via la barre de recherche. Permet la navigation rapide vers les pages, la création d'un nouveau lead, la bascule du thème, l'export CSV. Doit indexer les leads et clients pour autocomplétion.

Sélecteur de Vue (rôle actif)

Dropdown spécifique distinguant deux groupes : **Mes rôles** (les rôles réellement assignés, fonctionnels) et **Aperçu (lecture seule)** (les autres rôles, à des fins de vérification visuelle pour le Super Admin). Le label visible affiche `Vue · {rôle.short}`.

4.2 Dashboard

Page d'accueil par défaut, fournissant une vue synthétique de la performance commerciale et financière sur la période sélectionnée. Les indicateurs s'adaptent au rôle actif : un commercial voit ses indicateurs personnels, un Super Admin voit la vue globale, un planificateur voit la vue globale en lecture.

Composants attendus

- **Bandeau de filtres globaux** hérité de la topbar (Période + Activité), agissant en cascade sur tous les blocs.
- **KPIs principaux** : Leads reçus, Devis envoyés (nb + montant), Devis signés (nb + montant), CA encaissé, Taux de transformation, Panier moyen.
- **Bloc CA décomposé** : CA global avec ventilation Devis envoyés / Signés / Encaissés. Périodicité granulaire (jour, 7 j, 30 j, mois, trimestre, année, tout).
- **Courbe d'évolution 30 jours** (multi-séries : leads, devis envoyés, devis signés, CA signé).
- **Funnel de conversion** par étape (Lead → Envoyé → Ouvert → Signé → Encaissé).
- **Top commerciaux** du mois (Super Admin uniquement) avec sparkline individuelle par commercial.
- **Donut « CA signé par secteur »** (4 secteurs).
- **Carte de couverture France** avec densité de leads par département.
- **Filtre Canal Mano / Auto** spécifique au Dashboard, pour mesurer la performance comparée des deux voies.

4.3 Pipeline commercial

Vue Kanban en **six colonnes** représentant les étapes du cycle commercial. Chaque carte représente un lead avec son client, son montant estimé, son secteur (badge coloré), son commercial (avatar) et ses sous-statuts. Le commercial ne voit que ses cartes ; le Super Admin voit toutes les cartes ; le Planificateur n'a pas accès. Une bascule **Kanban / Liste** est disponible.

Les 6 colonnes

Lead entrant Nouveau lead, pas encore traité	Devis envoyé Sous-statut Mano ou Auto requis	Devis ouvert Le client a ouvert le lien (tracking signature)
Signé Sous-statut Sans/Avec acompte requis	Encaissé Facture finale payée	Perdu Lead non converti (visuel barré, opacité réduite)

Sous-statuts visuels obligatoires

Les badges secondaires sont **REQUIS** sur toute carte ayant atteint « Devis envoyé » ou au-delà. Un badge rouge « **Canal manquant** » est affiché si le sous-statut d'envoi n'est pas renseigné, pour forcer la qualification.

Catégorie	Sous-statut	Icône	Description
Envoi	mano	☐	Le commercial a envoyé le devis manuellement après accord téléphonique
Envoi	auto	⚡	Séquence email n8n déclenchée par le commercial (prospect injoignable)
Signature	sans	○	Devis signé, paiement à la livraison
Signature	avec	☐	Acompte dû ⇒ génération automatique de la facture d'acompte

Interactions Kanban

- Drag & drop entre colonnes pour faire évoluer le statut.
- Au survol d'une carte en colonne « Lead entrant » ou « Devis envoyé · Mano », un bouton « **Lancer séquence** » apparaît (déclenche le modal de confirmation n8n flow #2).
- Au clic sur une carte, navigation vers la fiche lead détaillée (</leads/{id}>).
- Filtres locaux (en plus des filtres globaux) : par commercial (sauf en vue Commercial où ce filtre est masqué), par fourchette de montant.

4.4 Leads & devis (table dense)

Vue tableau de tous les leads visibles pour le rôle actif, exportable en CSV via la palette de commandes ou un bouton dédié. Recherche, tri et filtrage avancé.

Colonnes

ID lead (court), date de réception, client (nom + ville), téléphone, secteur (badge), commercial (avatar + nom), source (icône + label), montant, dernier statut, dernière action (label + date), prochaine relance prévue.

Filtres dédiés

En complément des filtres globaux : statut (multi), commercial (Super Admin), source (multi). Une bascule permet d'afficher les leads **perdus** (masqués par défaut).

4.5 Fiche lead détaillée

Vue accessible via </leads/{id}> . Page complète présentant l'ensemble des informations et actions disponibles sur un lead.

Sections

- **En-tête** : nom client, secteur, commercial assigné, statut actuel + sous-statuts, montant, source, ville, dernière action.
- **Coordonnées** : téléphone, email, adresse, identifiant fiscal si pro.
- **Devis associés** : liste des devis générés pour ce lead, avec liens vers la vue Document.
- **Factures associées** : factures d'acompte et finale, avec leur statut d'encaissement.
- **Timeline d'activité** : événements chronologiques (création, changement de statut, appels, emails, notes), reconstruite côté serveur.
- **Annotation Immobilier / Travaux** : champ confidentiel visible uniquement si `permissions.immobTravaux === true`.
- **Boutons d'action** : Générer devis, Lancer séquence, Marquer perdu, Modifier les coordonnées, Réassigner.

4.6 Commerciaux — performance et classement

Visible par le Super Admin uniquement. Tableau de classement de l'équipe avec, par commercial : leads attribués, devis envoyés, devis signés, taux de transformation, CA signé, panier moyen, sparkline d'évolution. Comparatif visuel sous forme de barres horizontales. Filtrable par période et activité (filtres globaux).

4.7 Planification & opérations

Planning des interventions, partagé par les deux planificateurs. Quatre blocs temporels : **Aujourd'hui**, **Cette semaine**, **À venir**, **Passées**. Chaque ligne représente une intervention avec : date (numéro + mois en majuscules), client, adresse, technicien (avatar + nom), secteur (badge), créneau horaire (heure + durée), statut (Planifié / Réalisé / À facturer).

KPIs en haut de page

- **Acomptes à encaisser** (compte + montant total) — en orange (`tone="warning"`).
- **Aujourd'hui** (compte d'interventions) — en bleu primaire.
- **Cette semaine** (compte d'interventions à venir) — en info.
- **À facturer** (compte post-réalisation) — en vert (`tone="success"`).

Encart « Acomptes à encaisser »

Bandeau jaune dédié, listant les leads en statut **Signé · Avec acompte** dont l'acompte n'a pas encore été encaissé. Chaque ligne expose un bouton « **Encaisser** » qui marque l'acompte comme reçu et débloque la planification de l'intervention.

Filtres

Filtre par technicien (dropdown), filtre par statut d'intervention (Planifié / Réalisé / À facturer).

Actions disponibles

- Créer une intervention à partir d'un devis signé.
- Réassigner un technicien.
- Décaler un créneau (drag & drop).
- Marquer comme réalisé (déclenche la possibilité d'émettre la facture finale).
- Annuler avec motif (l'annulation conserve l'historique et bloque la facturation).

4.8 Comptabilité (module dédié)

Module remplaçant l'ancien écran « Facturation ». Page centrale de la comptabilité avec en-tête riche, KPIs globaux, et trois onglets : **Devis**, **Factures d'acompte**, **Factures finales**. Une page séparée **Clients** est accessible depuis cette page.

KPIs en haut

Devis en attente	Nombre de devis Envoyés ou Ouverts (non signés) + total TTC.
Acomptes à encaisser	Nombre de factures d'acompte émises non encore payées + total TTC.
Finales à encaisser	Nombre de factures finales émises non encore payées + total TTC.
CA encaissé (mois)	Total des acomptes + finales payés sur le mois en cours.

Onglets et statuts par type de document

Type	Préfixe num.	Statuts possibles
Devis	DEV-2026-0001	Brouillon · Envoyé · Ouvert · Signé · Refusé · Expiré
Facture d'acompte	FA-2026-0001	Brouillon · Envoyée · Payée · En retard
Facture finale	FAC-2026-0001	Brouillon · Envoyée · Payée · En retard

Tableau des documents

Colonnes communes : Numéro (mono), Client (nom + ville), Entité émettrice (puce de couleur + nom), Date d'émission, Échéance (factures) ou Validité (devis), Total HT, Total TTC, Statut (badge coloré), menu d'actions (Voir, Télécharger PDF, Envoyer par email, Dupliquer). L'onglet Devis affiche en plus une colonne **Canal** (Mano / Auto / Manquant).

Filtres locaux du module

Recherche (numéro ou nom client), filtre Entité émettrice, filtre Statut (selon le type de l'onglet actif).

4.9 Page Clients

Accessible via `/clients` depuis la page Comptabilité ou la palette de commandes. Liste des clients de l'entreprise, qu'ils soient issus d'un lead converti ou créés manuellement (clients directs hors acquisition digitale).

Caractéristiques d'un client

- **Type** : `pro` (entreprise) ou `particulier`.
- **Origine** : `lead` (issu d'un lead) ou `direct` (créé manuellement).
- **Identité** : raison sociale ou nom complet, contact référent, email, téléphone.
- **Adresse** : adresse, code postal, ville.
- **Pro** : SIRET, n° TVA intracommunautaire (champs requis si type = pro).
- **Activités historisées** : secteurs sur lesquels le client a déjà signé.
- **Note** : champ libre.

Filtres et actions

Recherche (nom ou contact), filtre Type (pro / particulier), filtre Origine (lead / direct). Bouton « **Nouveau client** » qui ouvre le formulaire de création (page séparée `/clients/new`). Au clic sur une ligne, navigation vers la fiche client (`/clients/{id}`) avec historique des documents et CA encaissé.

4.10 Éditeur de devis

Page accessible via `/devis/new` avec paramètres optionnels `?lead={id}` ou `?client={id}` pour pré-remplir le contexte. Permet la création d'un devis ligne par ligne à partir du **catalogue de prestations**.

Sections de l'éditeur

- **En-tête du document** : sélection du client (existant ou création rapide), entité émettrice (par défaut selon le mapping activité, override possible), modèle (selon Activité × Entité), date d'émission, validité (par défaut J+30).
- **Lignes de prestation** : ajout depuis le catalogue (16 prestations préchargées par défaut, organisées par secteur), modification de la quantité, du prix unitaire, du taux de TVA, application d'une remise ligne.
- **Totaux** : Total HT, Total TVA (avec ventilation par taux si plusieurs taux), Total TTC, Acompte calculé selon le pourcentage par défaut du secteur, Solde dû.

- **Conditions** : sélection du terme de paiement (Comptant à réception · 30 jours fin de mois · 45 jours fin de mois · 60 jours), notes libres ajoutées au document.
- **Actions** : Sauvegarder en brouillon, Aperçu PDF, Envoyer au client (déclenche la signature électronique).

Catalogue de prestations (extrait)

Secteur	Prestation	Unité	Prix unitaire	TVA
ENR	Panneau photovoltaïque 400 Wc	unité	280 €	10 %
ENR	Onduleur hybride 5 kW	unité	1 450 €	10 %
Rénovation	Isolation murs ITE	m²	95 €	10 %
Rénovation	Réfection toiture	m²	145 €	10 %
Urgence	Intervention dépannage (forfait)	forfait	180 €	20 %
Urgence	Heure technicien	h	75 €	20 %
Nettoyage	Entretien bureaux (mensuel)	mois	480 €	20 %
Nettoyage	Nettoyage vitrerie	m²	8 €	20 %

Le catalogue complet contient 16 prestations dans la maquette de référence. Il doit être éditable depuis les paramètres (CRUD prestations).

4.11 Vue Document (PDF view)

Accessible via `/devis/{id}` ou `/factures/{id}`. Affichage formaté du document généré (devis, facture d'acompte, facture finale) reprenant toutes les mentions légales de l'entité émettrice, l'IBAN, les lignes, les totaux, le bandeau de signature électronique pour les devis non signés. Boutons : Télécharger PDF, Envoyer par email, Dupliquer, Marquer comme payé (factures), Régénérer (Super Admin / Planificateur).

4.12 Paramètres (6 sections)

L'écran `/settings` est segmenté en six sous-onglets accessibles au Super Admin uniquement.

4.12.1 Utilisateurs & rôles

Liste de l'équipe avec, par ligne : avatar coloré, nom, email + ville, badges des rôles assignés (Admin en rouge, autres en bleu), badges des activités autorisées (commerciaux), permission spéciale Immobilier/Travaux (badge mint si activée). Bouton « **Inviter un utilisateur** » en haut à droite. Au clic

sur une ligne : modal d'édition complet (rôles, activités, permissions, désactivation, réinitialisation de mot de passe).

4.12.2 Entités juridiques

Vue en cartes (grille auto-fit, 340 px min). Chaque carte affiche : raison sociale (en gros), forme juridique + SIRET, n° TVA + taux, code APE, IBAN (mono), badge des activités par défaut. Couleur d'accent gauche par entité. Bouton « **Nouvelle entité** » ouvrant un modal complet avec tous les champs (raison sociale, forme, SIRET, APE, n° TVA, taux TVA, franchise en base, adresse, contact, IBAN/ BIC, mentions légales libres, mapping activités par défaut).

4.12.3 Secteurs d'activité

Liste paramétrable. Chaque secteur expose : nom, court, couleur (CSS variable), emoji, fourchette de devis indicative, **pourcentage d'acompte par défaut, taux de TVA par défaut**. La liste initiale est :

Secteur	Fourchette devis	Acompte	TVA
Dépannage urgence	200 € – 800 €	0 %	20 %
Nettoyage	500 € – 3 000 €	20 %	20 %
Énergies renouvelables	8 000 € – 25 000 €	30 %	10 %
Rénovation bâtiment	15 000 € – 80 000 €	40 %	10 %

4.12.4 Modèles devis & factures

Bibliothèque de modèles indexée par **Entité juridique × Activité × Type** (Devis / Facture d'acompte / Facture finale). Au moment de générer un document, le CRM sélectionne automatiquement le modèle correspondant au mapping par défaut, avec possibilité d'override par le commercial. Chaque modèle est un fichier importé (DOCX / PDF) ou une rédaction inline (éditeur WYSIWYG simple) supportant des champs dynamiques (`{client.nom}` , `{prestation.libelle}` , `{prestation.montant_ht}` , `{tva}` , `{total_ttc}` , `{acompte.montant}` , etc.).

4.12.5 Sources de leads

Liste des sources d'acquisition. Sources par défaut : Google Ads (📄), Meta Ads (📄), Recommandation (📄), Site web (📄), Téléphone direct (📄). Compteur de leads attribués par source, activable / désactivable. Une source identifie l'origine du lead pour l'analytics et la facturation interne (commission par source si applicable).

4.12.6 Intégrations

État des connecteurs externes avec bouton de test / configuration. Connecteurs : Google Ads (sync GCLID + enhanced conversions), n8n (orchestration des workflows), Supabase (base + auth), Brevo

(séquences email), prestataire de signature électronique. Statut « Connecté » / « Non connecté » + dernière synchronisation.

4.13 Onboarding (premier login)

Au tout premier login d'un utilisateur (drapeau persisté côté navigateur ou côté serveur — préférer côté serveur pour suivre les utilisateurs), un modal d'onboarding multi-étapes s'affiche, présentant les fonctionnalités clés du CRM, les filtres globaux et le sélecteur de Vue. Le modal est fermable à tout moment et ne se ré-affichera plus.

4.14 Modes Light / Dark

L'application supporte un mode sombre activable via le footer de la sidebar (icône lune/soleil) ou via la palette de commandes. Le thème est persisté côté navigateur. Toutes les vues doivent être pleinement fonctionnelles dans les deux modes (contrastes, badges, graphiques).

Modèle de données

5.1 Vue d'ensemble

Le modèle de données s'articule autour d'une vingtaine d'entités principales liées par des relations 1-N et N-N. L'objectif de cette section est de fixer la structure logique des tables, leurs champs critiques et leurs contraintes d'intégrité. L'implémentation finale (PostgreSQL via Supabase) se fera à partir de migrations SQL versionnées dans le dépôt Git.

5.2 Entités principales

users

id (uuid, PK) · email (unique) · password_hash · first_name · last_name · phone · team (city) · color · is_active · last_login_at · created_at · updated_at

roles

id (uuid, PK) · slug (admin | commercial | planification | assistant) · label · description · icon

user_roles (multi-rôles)

user_id (FK users) · role_id (FK roles) · granted_at · granted_by (FK users) – PK composite (user_id, role_id)

user_activities (affectation par activité)

user_id (FK users) · activity_id (FK activities) · assigned_at – PK composite

user_permissions (granulaires)

user_id (FK users) · permission_key (text – ex: « immob_travaux ») · granted_at · granted_by – index unique (user_id, permission_key)

activities (secteurs)

id (uuid, PK) · slug · label · short · color · emoji · default_quote_min · default_quote_max · acompte_pct (numeric) · vat_rate (numeric) · is_active

lead_sources

id (uuid, PK) · slug · label · icon · color · is_active

legal_entities (entités juridiques)

id (uuid, PK) · legal_name · legal_form (enum SAS|SARL|EURL|SASU|EI|SCI) · siret · ape_code · vat_number · address (jsonb) · contact_email · contact_phone · website · iban (chiffré) · bic · default_vat_rate · is_vat_exempt · logo_url · color · legal_mentions (text) · created_at

legal_entity_activities (mapping)

legal_entity_id · activity_id · is_default – PK composite. Index unique partiel sur (activity_id) WHERE is_default = true (une seule entité par défaut par activité).

prestations (catalogue)

id (uuid, PK) · activity_id (FK activities) · label · unit (enum unité|forfait|h|m²|mois) · unit_price_ht (numeric) · vat_rate (numeric) · is_active · created_at

payment_terms

id (uuid, PK) · slug (comptant|30j|45j|60j) · label · days (integer)

leads

id (uuid, PK) · short_id (sequence) · external_id (idempotency, unique) · received_at · source_id · activity_id · owner_id (FK users) · entity_id (FK legal_entities) · client_first_name · client_last_name · client_company · is_company · client_email · client_phone · client_address (jsonb) · gclid · utm_* · status (enum 6 valeurs : lead | envoye | ouvert | signe | encaisse | perdu) · sub_envoi (enum nullable : mano | auto) · sub_signature (enum nullable : sans | avec) · estimated_amount · is_urgent · status_age · last_action_at · last_action_label · next_followup_at · immob_travaux_annotation (text, chiffré, conditionnel) · annotation_segment (enum nullable : immobilier | travaux | les_deux) · lost_reason · created_at · updated_at

clients

id (uuid, PK) · type (enum pro | particulier) · name · contact_name · email · phone · address (jsonb) · siret (nullable) · vat_intra (nullable) · source (enum lead | direct) · source_lead_id (FK leads, nullable) · sectors (array activity ids) · note · created_at

documents (devis + factures)

id (uuid, PK) · type (enum devis | acompte | finale) · num (string unique – ex DEV-2026-0001) · status (enum selon type) · lead_id (FK leads, nullable) · client_id (FK clients) · entity_id (FK legal_entities) · activity_id · issued_at · valid_until (devis) · due_at (factures) · payment_term_id · total_ht · total_vat · total_ttc · acompte_pct (devis avec acompte) · acompte_amount · acompte_deduit (facture finale) · solde_du · related_devis (string, num du devis source) · signature_request_id · signed_at · pdf_url · sent_to_email · paid_at · payment_reference · created_by · created_at

document_lines

id (uuid, PK) · document_id (FK documents) · prestation_id (FK prestations, nullable si saisie libre) · label · quantity · unit · unit_price_ht · vat_rate · discount_pct · total_ht (calculé) · order_index

interventions

id (uuid, PK) · lead_id · quote_document_id · planner_id · technician_id · planned_at · duration_hours · address (jsonb) · status (enum planifie | realise | a_facturer | annule) · cancellation_reason (nullable) · realized_at (nullable) · notes

technicians

id (uuid, PK) · name · initials · color · skills (array string) · is_active

audit_logs (append-only)

id (uuid) · user_id · action · entity_type · entity_id · before (jsonb) · after (jsonb) · ip_address · user_agent · created_at – index sur (entity_type, entity_id, created_at).

document_templates

id (uuid, PK) · type (devis | acompte | finale) · entity_id · activity_ids (array) · name · file_url ou content_html · variables (jsonb) · is_active · updated_at

5.3 Conventions et contraintes d'intégrité

- Toutes les clés primaires sont des UUID v4 (ou ULID si la traçabilité chronologique est nécessaire). Pas d'auto-incrément exposé.
- Tous les timestamps sont en UTC (`timestampz`). Conversion vers Europe/Paris à l'affichage.
- Les énumérations sont implémentées en types `ENUM` PostgreSQL versionnés.
- Les champs libres destinés à l'humain sont plafonnés en longueur et validés côté serveur.

- L' `external_id` sur les leads garantit l'idempotence du webhook : un même lead reçu deux fois n'est créé qu'une seule fois.
- Soft deletes préférés aux deletes physiques sur les entités métier (`deleted_at` , `deleted_by`), à l'exception des données personnelles soumises à demande RGPD d'effacement.
- Les numéros de documents (`DEV/FA/FAC`) sont générés via une séquence par type et par année, sans trous, conformément à la réglementation française.

5.4 Énumérations critiques (pour mémoire)

Énum	Valeurs
<code>lead_status</code>	lead · envoye · ouvert · signe · encaisse · perdu
<code>sub_envoi</code>	mano · auto
<code>sub_signature</code>	sans · avec
<code>doc_type</code>	devis · acompte · finale
<code>devis_status</code>	brouillon · envoye · ouvert · signe · refuse · expire
<code>facture_status</code>	brouillon · envoye · paye · retard
<code>intervention_status</code>	planifie · realise · a_facturer · annule
<code>role_slug</code>	admin · commercial · planification · assistant
<code>client_type</code>	pro · particulier
<code>client_origin</code>	lead · direct

SECTION 6

Architecture technique recommandée

6.1 Stack recommandée

Couche	Recommandation	Justification
Frontend	React 18 + Vite + TypeScript	Écosystème mature, types stricts, vitesse de build, large bibliothèque de composants UI réutilisables.
UI Kit	shadcn/ui + Tailwind CSS	Composants accessibles, styles cohérents, code copié localement (pas de dépendance opaque). Les tokens CSS définis dans la maquette (couleurs sectorielles, tailles, ombres) sont à reproduire fidèlement.
State / data	React Query (TanStack Query)	Cache intelligent, gestion fine des invalidations, optimistic updates, retries.
Backend	API REST sur Node.js (Fastify ou Hono) ou Supabase Edge Functions	Léger, performant, faible empreinte mémoire. Fastify pour les endpoints applicatifs, Edge Functions pour les webhooks et triggers DB.
Base de données	PostgreSQL via Supabase	Voir argumentaire détaillé section 6.2.
Authentification	Supabase Auth (JWT) + MFA TOTP	Intégré, sécurisé, supporte OAuth pour évolutivité.
Stockage fichiers	Supabase Storage	Bucket privé pour les PDF, accès via URL signées à TTL court (max 60 minutes).
Génération PDF	Puppeteer (Node) ou WeasyPrint (Python)	Rendu fidèle des modèles, gestion des fonts custom, respect strict de la mise en page.
Orchestration externe	n8n self-hosté	Déjà en place côté commanditaire, déclenchement par webhook, visualisation des flux.
Email transactionnel	Brevo (ex-Sendinblue)	Déjà en place, séquences email natives, deliverability solide en France.
Signature électronique	Yousign, DocuSign ou équivalent eIDAS	Conformité européenne, API mature, webhooks de cycle de vie.
Hébergement	Vercel ou Netlify (frontend), Supabase + Railway/Fly (backend)	Déploiement continu, scalabilité automatique du frontend, infra managée.
CI/CD	GitHub Actions	Tests, lint, audit de dépendances, build et déploiement automatisés.
Monitoring		Détection rapide des incidents en production, alerting Slack/email.

Couche	Recommandation	Justification
	Sentry (erreurs front + back) + Better Stack ou Logflare (logs structurés)	

6.2 Pourquoi Supabase comme socle data et plateforme back

Le choix de Supabase comme socle data est une recommandation forte. Les arguments suivants justifient ce choix par rapport à un PostgreSQL nu auto-hébergé, à Firebase ou à un BaaS propriétaire fermé.

6.2.1 PostgreSQL natif, sans verrouillage

Supabase repose sur un PostgreSQL standard, pas une base maison. La portabilité est totale : un dump `pg_dump` produit une base relationnelle classique réutilisable ailleurs. Pas de verrouillage propriétaire, pas de couche de traduction. Toutes les fonctionnalités PostgreSQL avancées restent disponibles (CTE récursives, fonctions PL/pgSQL, types JSONB, triggers, vues matérialisées, full-text search).

6.2.2 Row Level Security (RLS) — couche de sécurité native

Supabase encourage et facilite la mise en place de la **Row Level Security** de PostgreSQL. On écrit des politiques SQL qui s'exécutent à chaque requête et filtrent les lignes accessibles selon l'utilisateur authentifié. Pour ce CRM, c'est la pièce maîtresse du cloisonnement de données.

EXEMPLE — POLITIQUE RLS « UN COMMERCIAL NE VOIT QUE SES LEADS »

```
CREATE POLICY commercial_own_leads ON leads FOR SELECT USING (owner_id =
auth.uid() OR EXISTS (SELECT 1 FROM user_roles ur JOIN roles r ON r.id =
ur.role_id WHERE ur.user_id = auth.uid() AND r.slug = 'admin'));
```

Cette protection s'applique **au niveau base**, pas seulement côté UI. Même un attaquant forçant des requêtes via la clé anon ne peut pas exfiltrer les leads de ses collègues.

6.2.3 Auth, Storage, Realtime intégrés

Supabase fournit nativement l'authentification (JWT, sessions, MFA, magic links, OAuth), le stockage de fichiers (avec URLs signées et politiques d'accès), et un canal temps réel basé sur les changements PostgreSQL (utile pour rafraîchir le pipeline en direct). Cela évite d'assembler trois services tiers, accélère le démarrage et garantit que les permissions s'appliquent uniformément sur tous les canaux.

6.2.4 Tarification et coût total de possession

Le plan gratuit suffit pour les phases de prototypage. Le passage au plan payant couvre les besoins d'une PME jusqu'à des dizaines de milliers d'utilisateurs et plusieurs gigaoctets de données. À périmètre comparable, l'auto-hébergement d'un PostgreSQL répliqué + un service d'auth + un stockage objet + un monitoring revient plus cher en heures d'ingénierie qu'en frais de licence Supabase.

6.2.5 Migrations versionnées et workflow d'équipe

Supabase CLI permet de versionner le schéma sous forme de migrations SQL dans Git, de tester en local sur une réplique fidèle, d'appliquer en staging puis en production via la CI. Plus de divergence de schéma entre environnements.

6.2.6 Stratégie de sortie

Sortir de Supabase consiste à exporter le dump PostgreSQL, exporter les fichiers du Storage, et réimplémenter l'auth (Cognito, Auth0, Keycloak ou maison). C'est un effort cadré, pas un re-développement complet, contrairement à un BaaS propriétaire fermé.

6.3 Authentification

Supabase Auth en mode email + mot de passe. **MFA TOTP obligatoire pour le rôle Super Admin**, recommandée pour les autres rôles, configurable par l'utilisateur. Politique de mot de passe : minimum 12 caractères, vérification anti-réutilisation contre la liste publique haveibeenpwned via l'API officielle. Magic link désactivé pour ce contexte B2B (les comptes nominatifs doivent avoir un mot de passe robuste). Sessions JWT avec rafraîchissement, expiration absolue à 12 heures. Logout serveur effectif (invalidation des refresh tokens).

6.4 API et webhooks

Trois familles d'endpoints à exposer :

- **API applicative** : consommée par le frontend, authentification JWT, RLS Supabase active. Nommage RESTful.
- **Webhooks entrants** : `POST /api/webhooks/leads/inbound`, `POST /api/webhooks/signature/{event}`, `POST /api/webhooks/email/{event}`. Authentification par signature HMAC partagée.
- **Webhooks sortants** : `POST {n8n_url}/leads/sequence/start` déclenché lors du clic « Lancer séquence ». Authentification par token bearer.

6.5 Environnements et déploiement

Trois environnements isolés : **local** (Supabase CLI), **staging** (projet Supabase séparé, déploiement continu sur la branche staging), **production** (projet Supabase séparé, déploiement manuel via tag de

release sur la branche main). Pas d'accès production accordé en lecture/écriture aux développeurs par défaut : tout passe par migrations versionnées et déploiements scriptés.

Intégrations externes

7.1 n8n — orchestration des workflows

n8n est l'outil d'orchestration externe pour les workflows métier qui dépassent le périmètre strict du CRM. Deux workflows sont à interconnecter dès la v1.

Flow #1 — Réception de leads

Le workflow #1 capte les soumissions de formulaires sur les landing pages (via webhook ou polling) et les appels qualifiés. Il normalise les données, les enrichit éventuellement, et appelle l'endpoint `POST /api/webhooks/leads/inbound` du CRM. Le payload attendu est un JSON typé. La signature HMAC du payload doit figurer dans le header `X-Signature`, calculée sur le body brut avec un secret partagé.

Flow #2 — Séquence de relance email

Déclenché manuellement depuis le CRM par le commercial pour relancer un prospect non joignable. Le CRM appelle `POST {n8n_url}/leads/sequence/start` avec l'identifiant du devis et les paramètres optionnels de séquence. n8n orchestre l'envoi des 4 emails programmés via Brevo. Chaque email contient le lien personnalisé de signature électronique du devis. La séquence s'arrête automatiquement si le client signe ou répond.

7.2 Brevo — emails transactionnels et séquences

Brevo est l'outil d'envoi d'emails. Trois usages principaux : envoi unitaire d'un devis (suivi d'ouverture / clic), séquence de relance déclenchée par le flow #2 (4 emails à J+0, J+3, J+7, J+14), notifications internes. Les templates Brevo sont configurés et synchronisés via API. Le CRM ne fait jamais d'envoi SMTP direct ; tout passe par l'API Brevo (pour bénéficier du tracking de délivrabilité, des bounces, des désinscriptions, et de la conformité opt-out).

7.3 Signature électronique conforme eIDAS

Le prestataire de signature (Yousign, DocuSign ou équivalent compatible eIDAS) est invoqué chaque fois qu'un devis est envoyé au prospect. Le devis PDF est uploadé au prestataire avec les coordonnées du signataire ; le prestataire retourne une URL de signature personnalisée qui est insérée dans l'email. Les événements de cycle de vie (envoyé, ouvert, signé, expiré, refusé) sont notifiés au CRM via webhook (`POST /api/webhooks/signature/{event}`) qui met à jour le statut du devis et du lead.

NIVEAU DE SIGNATURE RECOMMANDÉ

Signature électronique **avancée** (eIDAS niveau intermédiaire) — équilibre coût / valeur juridique pour des devis B2B/B2C de quelques centaines à dizaines de milliers d'euros. La signature qualifiée est rarement nécessaire sauf cadre réglementaire spécifique.

7.4 Google Ads — synchronisation des conversions

Pour optimiser la performance des campagnes Google Ads, le CRM remonte automatiquement les conversions hors-ligne via **Google Ads Enhanced Conversions for Leads**. À chaque transition de statut significative (Devis signé, Encaissé), le CRM appelle l'API Google Ads avec le GCLID du lead et la valeur de conversion (`conversion_value` = montant TTC du devis). Cela permet l'optimisation Smart Bidding sur la valeur réelle business, pas sur les leads bruts.

7.5 Catalogue des intégrations à exposer dans Paramètres

Intégration	Statut initial	Configuration requise
Google Ads	Connecté	OAuth + Customer ID + conversions configurées côté Google Ads
n8n	Connecté	URL d'instance + secret HMAC partagé
Supabase	Connecté	Projet + clés API (anon publique, service privée serveur uniquement)
Brevo	Non connecté à activer	Clé API + IP de sortie autorisée
Signature électronique	Non connecté à activer	Compte prestataire + clé API + URL de webhook callback

Sécurité informatique — points de vigilance

Le CRM stocke et manipule des données personnelles de prospects (nom, email, téléphone, adresse), des données contractuelles (devis signés, factures), et des coordonnées bancaires (RIB des entités émettrices, références d'encaissement). Le niveau d'exigence sécurité est élevé. Cette section liste les points de vigilance à traiter systématiquement.

8.1 Authentification et gestion des sessions

- Mots de passe stockés en hash bcrypt (cost ≥ 12) ou Argon2id (jamais en clair, jamais SHA-256 simple).
- Politique de complexité : minimum 12 caractères, vérification anti-réutilisation contre HaveIBeenPwned.
- MFA TOTP **obligatoire** pour le Super Admin, recommandée pour les autres rôles.
- Verrouillage temporaire de compte après 5 tentatives infructueuses (backoff exponentiel).
- Sessions JWT avec rotation des refresh tokens, expiration absolue à 12 heures.
- Logout serveur effectif (invalidation des tokens, pas seulement suppression côté client).
- Détection de sessions concurrentes suspectes (changement brutal d'IP / user agent → alerte + force re-auth).
- Pas d'auto-login via paramètre URL ou cookie tiers.

8.2 Row Level Security (RLS) Supabase — discipline d'équipe

Toute table contenant des données métier sensibles doit avoir RLS activée et au moins une politique `SELECT`, `INSERT`, `UPDATE` et `DELETE` définie explicitement. Les politiques sont versionnées dans les migrations SQL. Aucune requête frontend ne contourne la RLS — la clé technique `service_role` n'est utilisée que côté serveur, jamais exposée au navigateur.

ERREUR CLASSIQUE À ÉVITER

Exposer la clé `service_role` dans le bundle frontend, même par inadvertance dans une variable d'environnement préfixée par `NEXT_PUBLIC_` ou `VITE_`. Cette clé donne un accès total bypassant la RLS. Audit de build automatisé obligatoire avant chaque mise en production (script qui scanne le bundle final pour détecter toute clé sensible).

8.3 Protection des données personnelles (RGPD)

- Registre des traitements documenté : finalités, durées de conservation, destinataires.
- Mention RGPD sur les formulaires landing pages (consentement explicite à la prise de contact).
- Procédure de droit d'accès : un prospect peut demander l'export de ses données via un formulaire dédié → endpoint réservé au DPO.
- Procédure de droit à l'effacement : suppression effective et propagation aux backups après période de rétention légale.
- Durée de conservation par défaut : 3 ans après dernier contact pour les leads non transformés, 10 ans pour les pièces comptables (factures) conformément au Code de commerce français.
- Sous-traitants documentés (Supabase, Brevo, Yousign, n8n, Google Ads) avec contrats DPA signés.
- Hébergement des données en Union européenne (Supabase EU, Brevo France ou EU).

8.4 Sanitization et injections

- Toute entrée utilisateur est validée côté serveur (schéma Zod ou équivalent) avant d'atteindre la base.
- Pas de concaténation de chaînes pour les requêtes SQL — requêtes paramétrées exclusivement.
- Échappement HTML systématique dans les modèles de devis et factures (un client malicieux ne doit pas pouvoir injecter du JS dans un PDF rendu côté serveur via un champ libre).
- Validation des fichiers uploadés (logos d'entités, modèles de devis) : type MIME réel (pas seulement l'extension), taille plafonnée, scan antivirus si possible.
- Protection CSRF sur les endpoints sensibles (tokens anti-CSRF côté navigateur, samesite cookies).
- Headers de sécurité globaux : `Content-Security-Policy`, `X-Frame-Options: DENY`, `Strict-Transport-Security`, `Referrer-Policy: strict-origin-when-cross-origin`.

8.5 Chiffrement

- **En transit** : TLS 1.3 obligatoire sur tous les endpoints, redirection automatique HTTP → HTTPS, HSTS activé avec preload.
- **Au repos** : Supabase chiffre la base par défaut (AES-256 sur les disques). Les buckets Storage également.
- **Champ confidentiel** : l'annotation Immobilier/Travaux est chiffrée applicativement (AES-GCM) avec une clé stockée dans un coffre (Doppler, 1Password Secrets, Hashicorp Vault, ou Supabase Vault). La RLS contrôle l'accès, le chiffrement applicatif rend la lecture impossible même en cas d'accès direct à la base.
- **IBAN / RIB** des entités juridiques : chiffrés applicativement et masqués à l'affichage (ex. `FR**...1234`) sauf si l'utilisateur a explicitement déchiffré la donnée pour effectuer une saisie comptable.

8.6 Audit logs

Toutes les actions sensibles sont journalisées dans la table `audit_logs` en mode append-only. Actions tracées : login / logout, modification de rôle, attribution / révocation de la permission Immobilier/Travaux, génération de devis, émission de facture, encaissement, suppression de lead, accès au champ confidentiel, modification d'entité juridique, modification d'un modèle documentaire. Les logs sont conservés 5 ans minimum, accessibles uniquement au Super Admin via une vue dédiée. Champs : qui (`user_id`), quoi (`action`), sur quoi (`entity_type` + `entity_id`), quand (`timestamp UTC`), depuis où (`IP`, `user agent`), avant/après (`jsonb`).

8.7 Rate limiting et anti-abuse

- Endpoints publics (webhooks, login) : rate limiting strict par IP (ex. 10 req/min sur le login).
- Endpoints authentifiés : rate limiting par utilisateur (ex. 100 req/min) pour bloquer les scripts agressifs.
- Anti-énumération : pas de différenciation entre « email inconnu » et « mot de passe incorrect » sur l'endpoint login. Délai de réponse constant.
- Captcha sur les formulaires LP (côté n8n / front public, pas côté CRM).
- Protection contre le scraping (User-Agent inconnus traités comme suspects au-delà d'un seuil).

8.8 Sauvegardes et plan de reprise

- Sauvegardes PostgreSQL automatisées par Supabase, rétention 7 jours sur le plan Pro, 30 jours sur Team.
- Sauvegarde supplémentaire externalisée hebdomadaire (dump `pg_dump` chiffré, stockage S3 ou équivalent) pour parer à un incident côté Supabase.
- RTO cible : 4 heures (temps maximal de remise en service après incident majeur).
- RPO cible : 1 heure (perte de données maximale acceptable).
- Test de restauration semestriel documenté dans un runbook à conserver à jour.

8.9 Conformité signature électronique eIDAS

La signature obtenue via le prestataire choisi doit être au minimum de niveau « avancé » au sens du règlement eIDAS européen. Le dossier de preuve (certificat horodaté, IP signataire, audit trail des étapes) doit être stocké durablement (10 ans minimum pour aligner sur la prescription commerciale française) et joint à chaque devis signé dans le CRM.

8.10 Gestion des secrets

- Aucun secret en clair dans le code source ou dans Git. Pre-commit hook avec `gitleaks` pour bloquer les commits contenant des secrets.

- Variables d'environnement gérées par un coffre (Doppler, GitHub Secrets pour la CI, Supabase Vault pour les secrets exposés à des fonctions DB).
- Rotation des clés API tierces tous les 6 mois minimum, ou immédiatement en cas de suspicion de fuite.
- Distinction claire entre clés publiques (anon key Supabase, exposable) et clés serveur (service_role, jamais exposée).

8.11 Sécurité des dépendances

- Audit automatique `npm audit` ou équivalent en CI, blocage des PR avec vulnérabilités critiques.
- Outil de surveillance type Dependabot ou Renovate pour les mises à jour de dépendances.
- Lockfile (`package-lock.json` ou `pnpm-lock.yaml`) commité, builds reproductibles.
- Revue manuelle avant ajout de toute nouvelle dépendance tierce, en privilégiant les packages largement adoptés et maintenus.

8.12 Vigilance spécifique au stockage des PDF générés

Les PDF de devis et factures contiennent des informations à la fois personnelles (client) et stratégiques (montants commerciaux). Stockage exclusivement dans un bucket Supabase Storage **privé**. Accès uniquement via URL signées à TTL court (max 60 minutes). Aucun PDF ne doit être servi via une URL publique permanente. Les liens d'envoi par email passent par un endpoint relais qui régénère une URL signée à chaque requête.

Performance, accessibilité et UX

9.1 Temps de réponse cibles

Action	Temps cible (p95)
Chargement initial du Dashboard	< 2,5 s
Navigation interne (changement d'écran)	< 800 ms
Filtre / tri sur une liste de 1000 leads	< 500 ms
Génération PDF d'un devis	< 3 s
Réception webhook lead → visible dans le CRM	< 5 s
Drag & drop carte Kanban → mise à jour DB	< 400 ms (optimistic)

9.2 Pagination, lazy loading, optimistic updates

- Pagination serveur sur toutes les listes susceptibles de dépasser 100 éléments (Leads & devis, Comptabilité, Audit logs).
- Lazy loading des composants lourds (graphiques, carte de France).
- Optimistic updates sur les actions à faible risque (drag & drop dans le pipeline) avec rollback en cas d'erreur serveur.
- Cache court côté client (React Query) avec invalidation à la mutation. Stratégie `stale-while-revalidate` pour les KPIs Dashboard.
- Précalcul des KPIs lourds en **vue matérialisée** (rafraîchie toutes les 5 minutes) pour éviter les agrégations en temps réel sur les gros volumes.

9.3 Accessibilité

- Cible WCAG 2.1 AA.
- Contrastes texte / fond conformes (vérifiables via Lighthouse).
- Navigation clavier complète (focus visibles, ordre logique).
- Attributs ARIA sur les composants interactifs custom (Kanban, modales, palette de commandes).
- Mode sombre disponible (toggle déjà présent dans la maquette), avec contrastes recalibrés.

- Tailles de texte minimales : 12 px pour les labels, 14 px pour le corps.

9.4 Responsive

L'application est **desktop-first**. Les écrans cibles sont dimensionnés pour 1280 × 800 minimum. Une vue tablette (10 pouces) est attendue pour les commerciaux en mobilité — le Pipeline doit notamment rester utilisable en mode tactile (drag & drop). Le mobile (smartphone) n'est pas un cas d'usage prioritaire à la v1, mais l'interface ne doit pas casser visuellement.

Roadmap de développement proposée

Phase 1 — MVP fonctionnel (≈ 8 semaines)

- Modèle de données complet, RLS Supabase activée sur toutes les tables, migrations versionnées.
- Authentification, gestion des utilisateurs et rôles, multi-rôles, sélecteur de Vue (sans aperçu lecture seule).
- Modules Dashboard (KPIs principaux + courbe + funnel), Pipeline 6 colonnes avec sous-statuts, Leads & devis.
- Génération de devis (modèle simple, un seul template), signature électronique de bout en bout.
- Réception webhook flow #1, déclenchement webhook flow #2.
- Émission manuelle de la facture finale.

Phase 2 — Production complète (≈ 6 semaines)

- Module Comptabilité complet (3 onglets, KPIs, filtres, vue Document, éditeur de devis avec catalogue prestations).
- Page Clients (pro/particulier, lead/direct), formulaire de création, fiche client.
- Multi-entités juridiques, mapping Activité × Entité, modèles de devis et factures complets.
- Génération automatique de la facture d'acompte au statut « Signé · Avec acompte ».
- Module Planification complet, encart « acomptes à encaisser », assignation de techniciens, drag & drop des créneaux.
- Annotation Immobilier/Travaux avec permission granulaire et chiffrement applicatif.
- Synchronisation Google Ads Enhanced Conversions.
- Onboarding au premier login, palette de commandes , mode sombre, mode aperçu lecture seule.

Phase 3 — Optimisation et observabilité (≈ 4 semaines)

- Audit logs complets et écran d'audit dédié au Super Admin.
- MFA TOTP obligatoire Super Admin, recommandée pour les autres.
- Rate limiting fin, monitoring Sentry, tests de charge.
- Optimisation des requêtes lentes, vues matérialisées sur les KPIs Dashboard.
- Activation du rôle Assistant (périmètre à formaliser).
- Tests end-to-end automatisés sur les parcours critiques.

- Documentation utilisateur et runbook opérationnel.

Critères d'acceptation

11.1 Fonctionnels

- ✓ Un commercial reçoit en temps réel un lead créé par le webhook flow #1, attribué automatiquement selon ses activités.
- ✓ Un commercial peut générer un devis depuis le catalogue de prestations, l'envoyer au prospect, obtenir une signature électronique conforme eIDAS.
- ✓ Le sous-statut Mano / Auto est obligatoire et un badge rouge « Canal manquant » s'affiche tant qu'il n'est pas renseigné.
- ✓ Un commercial peut déclencher manuellement la séquence n8n flow #2 (4 emails) et le statut bascule en « Devis envoyé · Auto ».
- ✓ Quand un devis passe en « Signé · Avec acompte », la facture d'acompte est générée automatiquement et envoyée au client par email.
- ✓ Le pourcentage d'acompte appliqué correspond au paramétrage de l'activité (0 % urgence / 20 % nettoyage / 30 % ENR / 40 % rénovation).
- ✓ Un planificateur voit l'ensemble des chantiers, encaisse l'acompte via le bouton dédié, planifie une intervention, marque comme réalisée, émet la facture finale et suit l'encaissement.
- ✓ Le Super Admin gère les utilisateurs, les rôles, les activités, les entités juridiques, les modèles de documents.
- ✓ Le Super Admin attribue ou retire la permission Immobilier/Travaux ; un utilisateur sans cette permission ne voit ni le champ ni son contenu.
- ✓ Les filtres globaux Période et Activité s'appliquent sur tous les écrans de pilotage et persistent entre navigations.
- ✓ Le sélecteur de Vue propose les rôles assignés (fonctionnels) et les autres rôles (aperçu lecture seule).
- ✓ La page Clients distingue clients **pro** / **particulier** et origines **lead** / **direct**.
- ✓ Le module Comptabilité présente les 3 onglets (Devis, Acomptes, Finales) avec KPIs corrects et filtres opérationnels.
- ✓ La numérotation des documents est strictement séquentielle par type et par année (DEV/FA/FAC).

11.2 Non fonctionnels

- ✓ Les temps de réponse cibles de la section 9.1 sont tenus en p95 sur la base de production.

- ✓ Lighthouse score ≥ 90 sur Performance, Accessibilité, Best Practices.
- ✓ Toutes les tables sensibles sont protégées par des politiques RLS Supabase versionnées.
- ✓ Aucun secret n'est exposé dans le bundle frontend (audit de build automatisé en CI).
- ✓ Les sauvegardes sont opérationnelles et un test de restauration a été réalisé avec succès.
- ✓ L'audit log capture toutes les actions sensibles définies en 8.6.
- ✓ Les conformités RGPD et eIDAS sont documentées (registre des traitements, DPA signés, dossier de preuve par signature).
- ✓ L'IBAN des entités et l'annotation Immobilier/Travaux sont chiffrés applicativement.
- ✓ MFA TOTP fonctionnelle, exigée pour les Super Admin.

Glossaire technique, conventions et endpoints

A. Conventions de nommage

Élément	Convention	Exemple
Tables	snake_case, pluriel	leads , document_templates
Colonnes	snake_case	created_at , owner_id
Endpoints	kebab-case, RESTful	POST /api/leads/{id}/trigger-sequence
Composants React	PascalCase	LeadKanbanCard
Hooks	camelCase, préfixe use	useLeadsQuery
Variables env	SCREAMING_SNAKE_CASE	SUPABASE_SERVICE_ROLE_KEY
Migrations	YYYYMMDDHHMMSS_description	20260507_120000_create_leads.sql
Documents	{Préfixe}-{année}-{counter}	DEV-2026-0001 , FA-2026-0001 , FAC-2026-0001

B. Endpoints API recommandés (extrait)

Méthode	Endpoint	Description
POST	<code>/api/webhooks/leads/inbound</code>	Réception lead depuis n8n flow #1
POST	<code>/api/leads/{id}/trigger-sequence</code>	Déclenchement séquence relance n8n flow #2
GET / POST / PATCH	<code>/api/leads</code> et <code>/api/leads/{id}</code>	CRUD leads (RLS active)
POST	<code>/api/quotes</code>	Création d'un devis (via éditeur)
POST	<code>/api/quotes/{id}/send</code>	Envoi d'un devis (génère lien signature et envoie email)
POST	<code>/api/webhooks/signature/{event}</code>	Webhook événements signature électronique
POST (interne)	<code>/api/invoices/deposit/auto</code>	Génération auto facture d'acompte (sur trigger DB au passage signe+avec)
POST	<code>/api/invoices/{id}/mark-paid</code>	Encaissement d'une facture
GET	<code>/api/dashboard/kpis</code>	KPIs filtrés par période et activité
GET / POST	<code>/api/clients</code>	Liste / création client
GET / POST	<code>/api/legal-entities</code>	Gestion entités juridiques (Super Admin)
GET / POST	<code>/api/document-templates</code>	Gestion modèles documentaires (Super Admin)

C. Glossaire technique

RLS	Row Level Security — politique d'accès SQL appliquée ligne par ligne selon l'utilisateur connecté.
JWT	JSON Web Token — format standard de jeton d'authentification signé.
HMAC	Hash-based Message Authentication Code — signature cryptographique d'un payload pour vérifier l'authenticité d'un webhook.
eIDAS	Règlement européen sur l'identification électronique et les services de confiance — cadre juridique de la signature électronique.
RGPD	Règlement Général sur la Protection des Données — réglementation européenne sur les données personnelles.
DPA	Data Processing Agreement — contrat de sous-traitance RGPD avec un prestataire qui traite des données personnelles.
RTO / RPO	Recovery Time Objective / Recovery Point Objective — engagements de remise en service et de perte de données acceptable.
GCLID	Google Click Identifier — identifiant unique d'un clic Google Ads, utilisé pour remonter les conversions hors-ligne via Enhanced Conversions.
MFA / TOTP	Multi-Factor Authentication / Time-based One-Time Password — second facteur d'authentification basé sur un code à usage unique.
CSP	Content Security Policy — header HTTP qui restreint les sources de scripts/styles/images pour limiter les XSS.
HSTS	HTTP Strict Transport Security — header qui force le navigateur à utiliser HTTPS sur le domaine.
BaaS	Backend as a Service — plateforme fournissant base de données, auth, stockage et fonctions serveur en services managés.

FIN DU DOCUMENT

Toute question, ambiguïté ou décision en suspens identifiée par l'équipe de développement à la lecture de ce document doit être documentée en commentaire et arbitrée avant le démarrage du sprint correspondant. Le présent cahier des charges est versionné ; toute modification fait l'objet d'une release note.